

CornerShop Engineering: Code Review Guidelines

Version 2.3. Every pull request must be reviewed against these rules before it is merged into main.

1. Security

1.1	No secrets in code. Passwords, API keys and tokens come from environment variables.
1.2	All SQL uses parameterised queries (? placeholders). Never build SQL with f-strings, + or format().
1.3	Never log or print passwords, tokens or payment data.
1.4	Never call eval() or exec() on data, configuration or user input.
1.5	No special-case logins, master passwords or other backdoors.

2. Correctness

2.1	Validate inputs where they enter the system: percentages are 1-100, quantities are at least 1, prices are never negative.
2.2	Money is always integer cents. Never use floats for money.
2.3	No mutable default arguments (lists, dicts, sets). Use None.
2.4	Expiry dates are inclusive: a coupon expiring today is still valid today.
2.5	Never use a bare <i>except:</i> . Catch specific exceptions and log them.

3. Testing

3.1	Every new public function has tests for the normal case, edge cases and error cases.
3.2	Every bug fix comes with a test that would have caught the bug.
3.3	Never weaken or delete an existing test to make a change pass.

4. Style

4.1	Every public function has a docstring.
4.2	No magic numbers: business values (thresholds, fees, limits) are named constants.
4.3	Use the logging module, never print().
4.4	Imports go at the top of the file, unless needed to avoid a circular import.

5. Severity and verdict

Severity	Meaning	Examples
High	Security hole, data loss, wrong money, or untested business logic.	Rules 1.x, 2.2, 2.4, 3.1
Medium	Bug risk or hidden failure that is not immediately dangerous.	Rules 2.1, 2.3, 2.5

Low	Readability and maintainability.	Rules 4.x
-----	----------------------------------	-----------

Verdict: any High finding means **Request changes**. Only Medium or Low findings means **Approve with comments**. No findings means **Approve**.